

GRC102 – INFORMATION SECURITY GOVERNANCE

WEEK 1 PRACTICAL LABORATORY

INFORMATION SECURITY GOVERNANCE IN ACTION

GlobalHealth Connect (GHC) – Executive Governance Simulation

Student Name: Grace Makinde

Registration Number: C11/26/CGRCE/17557

Course: GRC102 – Information Security Governance

Course Week: Week 1

Submission Date: 11 September 2026

TASK 1 — GOVERNANCE BLUEPRINT

Evidence 1: Current-State Governance Gap Assessment

Introduction

GlobalHealth Connect (GHC) has experienced rapid growth, two acquisitions and a recent data-leakage near-miss. However, its information security governance has not developed at the same pace. The current approach is mainly ad-hoc, with unclear responsibilities and inconsistent processes. The key governance gaps are identified below.

Table 1: Evidence 1 — Current-State Governance Gap Assessment

Governance Area	Current Gap	Impact on GHC
Security accountability	Security ownership and accountability are unclear. The IT Manager currently performs some security activities, but there is no clear governance structure	Security issues may not have a clear owner, and important decisions may be delayed.

	showing who has final accountability.	
Policies and documentation	Policies are inconsistent, and some were inherited from the two acquired organisations.	Employees may be working with different security requirements, creating unnecessary risk.
Risk management	GHC is mainly reactive and does not have a formal proactive risk assessment process.	Important risks may not be identified and treated before they affect the organisation.
Board reporting	Technical security metrics exist but are not consistently connected to business impact.	The Board may find it difficult to understand the organisation's actual security position and make informed decisions.
Compliance	Compliance activities are mainly driven by audits rather than continuous monitoring.	GHC may become focused on preparing audits instead of maintaining compliance throughout the year.
Training and awareness	Annual security training is mandatory, but employee engagement is low.	Employees may complete training without developing strong awareness of their security responsibilities.
Cross-functional decision-making	The disagreement between the CTO and IT Manager over password policy shows that security decisions can create conflict between business and technical priorities.	Security decisions may be delayed or implemented without sufficient consideration of business needs.
Security oversight	There is no formal Security	There is limited cross-

	Steering Committee described in the current structure.	functional coordination for security priorities and major security decisions.
--	--	---

Overall Assessment

The main issue at GHC is not that security activities are completely absent. Some security activities are already being carried out, particularly within IT and compliance. The main weakness is that these activities are not supported by a clear governance structure, defined accountability, and regular executive oversight.

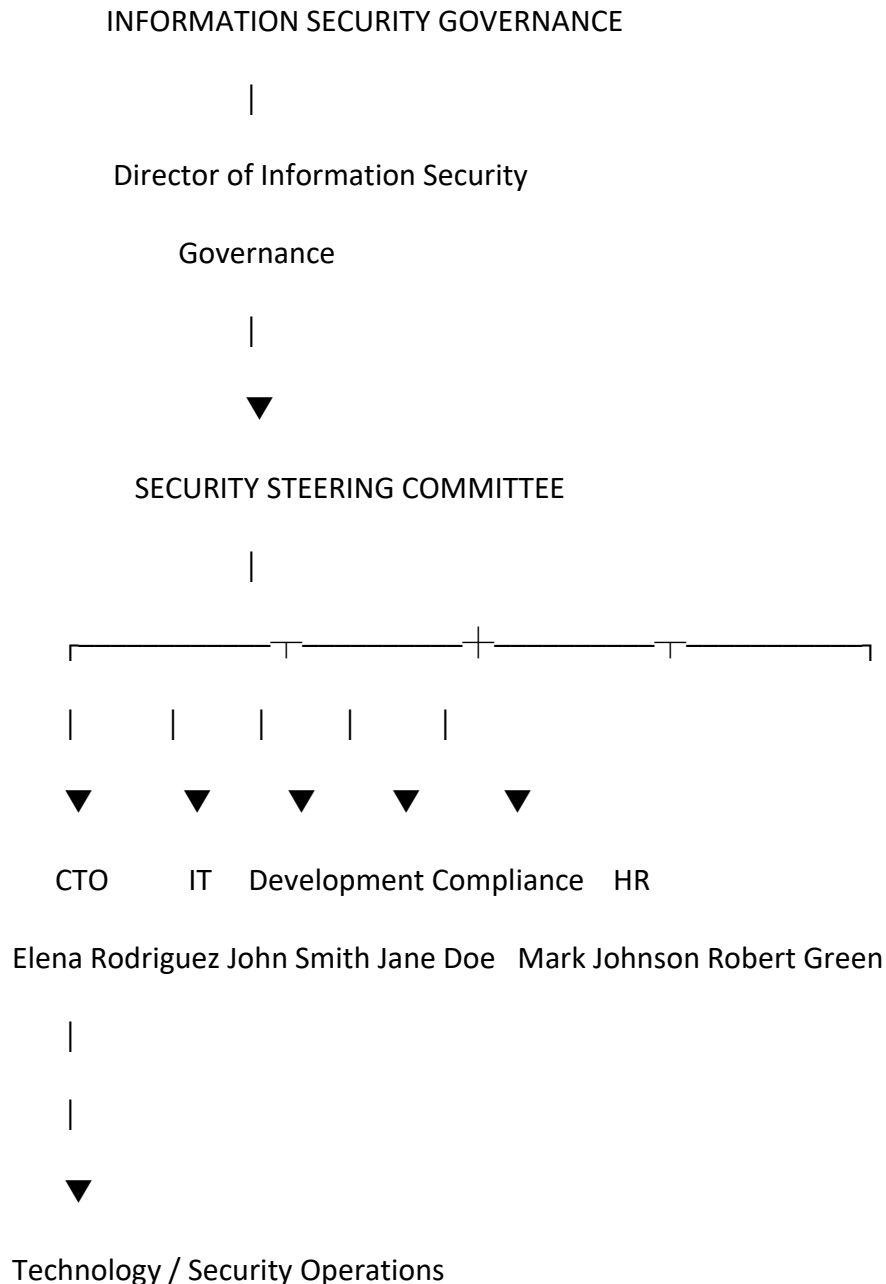
The current ad-hoc approach may have been manageable when GHC was smaller, but its rapid growth, acquisitions and increasing reliance on sensitive health information make a more structured approach necessary. The recent data-leakage near-miss also shows the need for GHC to move towards a more proactive and coordinated information security governance model.

Evidence 2: Proposed Security Governance Organisational Structure

Based on the governance gaps identified in Evidence 1, GHC needs a clear structure that defines security responsibilities and provides appropriate oversight. The proposed structure places information security governance under executive oversight while involving the key business and technology functions that contribute to security decisions.

Table 2: Evidence 2 — Proposed Security Governance Organisational Structure





The proposed structure places the Board at the oversight level, with the CEO providing executive accountability. The Information Security Governance function coordinates the security programme and reports significant risks and issues through the appropriate governance channels. The Security Steering Committee provides a cross-functional forum for IT, development, compliance, HR, and finance to participate in security decisions.

Evidence 3: RACI Responsibility Matrix

The RACI matrix below defines clear responsibilities for key information security governance activities at GlobalHealth Connect (GHC). It is designed to reduce ambiguity, improve accountability and ensure that security decisions involve the appropriate business, technology, and compliance stakeholders.

Table 3: Information Security Governance RACI Responsibility Matrix

Governanc e Activity	Director, Informatio n Security Governan ce	CE O	CT O	IT Manag er	Senior Develop er	Complian ce Officer	HR Manag er	CF O	Boar d
1. Security policy developme nt	R	I	C	C	C	C	I	I	I
2. Security policy approval	R	A	C	C	C	C	I	C	I
3. Enterprise security risk review	R	A	C	C	C	C	C	C	I
4. Incident response planning	A	I	C	R	C	C	C	I	I
5. Security awareness and training	A	I	C	C	C	C	R	I	I
6. Security metrics and	R	A	C	C	C	C	I	C	I

Board reporting									
7. Third-party security and compliance review	A	I	C	C	R	C	C	I	I
8. Major security incident escalation	R	A	C	R	C	C	I	I	I

Key Accountability Points

- The **Director of Information Security Governance** coordinates the overall security governance programme and is responsible for ensuring that governance activities are carried out.
- The **CEO** has final accountability for major security governance decisions, policy approval, enterprise security risk and Board reporting.
- The **CTO** provides technical input and ensures that security decisions are aligned with technology and development priorities.
- The **IT Manager** is responsible for operational security activities, particularly incident response planning and technical response.
- The **Compliance Officer** provides regulatory and compliance input, including third-party security reviews.
- The **HR Manager** is responsible for coordinating security awareness and training activities involving employees.
- The **CFO** is consulted where security decisions involve financial priorities, investment, or business risk.
- The **Board** receives appropriate information and oversight reports rather than becoming involved in routine operational security activities.

This RACI structure supports accountability by ensuring that each major governance activity has a clear owner while still involving the relevant business and technical stakeholders in decision-making.

Evidence 4: Governance Structure Rationale

The proposed governance structure gives GlobalHealth Connect (GHC) clear lines of accountability for information security. The Board provides oversight, while the CEO provides executive accountability for major security decisions and risk. The Director of Information Security Governance coordinates the security programme and ensures that security risks, policies and performance are properly managed and reported. The Security Steering Committee brings together key representatives from technology, IT, development, compliance, HR and finance so that security decisions are considered from different business perspectives.

The structure also supports transparency and business alignment by clearly defining who is responsible for carrying out security activities and who is accountable for the final decision. The RACI matrix helps prevent gaps or duplication of responsibility, while the involvement of business and technical stakeholders ensures that security decisions consider operational, financial, regulatory and technology requirements. This will help GHC move away from its current ad-hoc approach towards a more coordinated and proactive governance model.

TASK 2: INFORMATION SECURITY CHARTER

Evidence 5: GHC Information Security Charter

1. Purpose

The purpose of the GlobalHealth Connect (GHC) Information Security Charter is to establish a clear and consistent framework for protecting the organisation's information, systems, and services. The Charter supports the management of information security risks while ensuring that security activities remain aligned with GHC's business objectives.

The Charter is particularly important as GHC continues to grow, integrates acquired organisations and relies increasingly on cloud-based patient-management systems. It provides a foundation for protecting sensitive information, supporting regulatory requirements, maintaining customer trust, and reducing the likelihood and impact of security incidents.

2. Scope

This Charter applies to all GHC employees, contractors, temporary staff, consultants, and other individuals who have access to GHC information or information systems.

It covers information assets, cloud-based patient-management systems, applications, infrastructure, business systems, and sensitive patient and financial information. It also applies to relevant third parties, suppliers, service providers, and acquired organisations that access or process GHC information.

The Charter applies across all relevant business and support functions, including technology, IT operations, development, finance, human resources, legal and compliance.

3. Authority

The Information Security Charter is established under the authority of the CEO, with oversight from the Board. Executive management is responsible for supporting the implementation of the Charter and providing the resources required to manage information security effectively.

The Director of Information Security Governance is authorised to coordinate the information security governance programme, develop and maintain security governance processes, monitor significant risks, request relevant information from business and technology functions, and escalate unresolved security risks to executive management.

Significant security risks, major incidents, unresolved governance issues and decisions requiring substantial investment or risk acceptance will be escalated to the CEO and, where appropriate, the Board.

4. Roles and Responsibilities

Board: Provides oversight of information security governance, receives significant risk and security performance reports, and ensures that management remains accountable for protecting GHC's information and supporting regulatory obligations.

CEO – Sarah Chen: Provides executive leadership for information security, approves major security governance decisions and ensures that appropriate resources are available to manage significant security risks.

Director, Information Security Governance: Coordinates the information security governance programme, maintains the governance framework, monitors security risks, supports policy development, coordinates reporting and escalates significant issues to executive management.

CFO – Marcus Thorne: Provides financial and business-risk input to security investment decisions and supports management in assessing the financial impact of significant security risks.

CTO – Elena Rodriguez: Provides technology leadership and ensures that security requirements are considered within technology, development and innovation decisions.

IT Manager – John Smith: Implements and maintains operational security controls, supports incident response activities, manages technical remediation and reports relevant operational security issues.

Senior Developer – Jane Doe: Supports secure development practices and ensures that security considerations are incorporated into product development activities.

Compliance Officer – Mark Johnson: Provides regulatory and compliance guidance, monitors relevant healthcare obligations and supports compliance assessments and reviews.

HR Manager – Robert Green: Supports employee onboarding and offboarding controls, security awareness activities and the communication of relevant security responsibilities to staff.

All Employees and Contractors: Follow approved security policies and procedures, protect GHC information and systems, complete required security training and promptly report suspected security incidents or weaknesses.

5. Key Information Security Principles

GHC will apply the following principles when managing information security:

- **Risk-based approach:** Security decisions will be based on the likelihood and potential impact of identified risks.
- **Business alignment:** Security activities will support GHC's business objectives, including growth, innovation, operational efficiency, and customer trust.
- **Proportionate controls:** Security controls will be appropriate to the level of risk and the importance of the information or system being protected.
- **Clear accountability:** Security responsibilities will be clearly assigned so that decisions and actions have identifiable owners.

- **Continuous improvement:** GHC will regularly review its security practices and improve them based on risks, incidents, assessments and lessons learned.
- **Compliance and trust:** GHC will protect sensitive information and support its legal, regulatory and contractual obligations.

6. Reporting and Escalation

The Director of Information Security Governance will provide regular information security updates to executive management and the Security Steering Committee. Reports will include significant security risks, key security metrics, major incidents, compliance issues and progress against agreed security priorities.

Significant security incidents or risks that may affect patient information, customers, business operations, regulatory obligations or GHC's reputation will be escalated promptly to the CEO and other appropriate senior stakeholders. Material issues requiring Board oversight will be reported to the Board.

7. Review and Approval

This Charter will be reviewed at least annually and whenever there are significant changes to GHC's business, technology, regulatory requirements or risk environment. Any changes to the Charter will be documented, approved through the appropriate governance process and communicated to relevant stakeholders.

The CEO will approve the Charter, with Board oversight of the overall information security governance framework.

Evidence 6: Memo to CFO – Marcus Thorne

To: Marcus Thorne, CFO

From: Director, Information Security Governance

Subject: How the Information Security Charter Supports GHC's Strategic Goals

The Information Security Charter gives GHC a clear framework for managing information security as the organisation continues to grow. It clearly defines who is responsible for security decisions, how risks should be managed and escalated, and how security performance should be reported to management and the Board. This is important following the recent data-leakage

near-miss and the integration of two acquired organisations. A clear governance structure will help reduce gaps in responsibility and ensure that security risks are identified and addressed before they become larger business problems.

The Charter also supports GHC's strategic goals by connecting security activities and investment decisions to business needs. Instead of treating security as only an IT cost, management can use risk information to decide where resources and funding are most needed. This will help GHC protect patient and business information, meet regulatory requirements, maintain customer trust, and support future growth while making better-informed investment decisions.

Evidence 7: Board Executive Summary

Overall Security Posture: RED

GHC's overall security posture is currently **Red**. The six-month data shows that security threats and high-risk incidents are increasing, while the percentage of critical vulnerabilities being patched has declined. Although employee security training has improved, the increase in phishing, malware, and high-risk incidents shows that further action is needed.

Table 4: Board-Level Security Metrics and RAG Status

Security Area	Current Status	Trend	Board Interpretation
Phishing attempts	320	 Increasing	Increasing phishing activity creates a higher risk of credential theft and unauthorised access.
Malware incidents	50	 Increasing	The continued increase indicates growing exposure to malicious software and possible disruption

			to operations.
Critical vulnerabilities patched	55%	● Declining	More critical vulnerabilities are remaining unpatched, increasing the risk of exploitation.
Security training completion	70%	Improving	Training participation has improved, but further improvement is needed to reach stronger coverage.
High-risk security incidents	7	● Increasing	The increase in high-risk incidents indicates that the overall security risk is becoming more serious.

Key Board Message

The main concern for GHC is that several security risks are increasing at the same time. Phishing attempts increased from 150 in September to 320 in February, while malware incidents increased from 25 to 50. High-risk incidents also increased from 2 to 7 during the same period. In addition, the percentage of critical vulnerabilities patched fell from 67% to 55%. These trends suggest that GHC needs to strengthen preventive security measures and improve the speed at which important vulnerabilities are addressed.

Security training is showing a positive trend, increasing from 45% to 70%. However, the improvement in training has not yet been matched by a reduction in security incidents. Management should therefore continue improving employee awareness while giving priority to vulnerability management, phishing protection, and incident prevention.

Evidence 8: Selected Security Metrics, Six-Month Trends and Business Commentary

The following five metrics were selected because they provide the Board with a balanced view of GHC's security exposure, preventive controls, and employee awareness.

Table 5: Selected Board Security Metrics and Six-Month Trends

Metric	Six-Month Trend	Current Status	Business Commentary
Phishing attempts	Increased from 150 in September to 320 in February.	320 – High	The increase shows a growing threat to employees and accounts. Successful phishing could lead to unauthorised access, data loss or disruption to GHC's services.
Malware incidents	Increased from 25 in September to 50 in February.	50 – High	The increase may indicate greater exposure to malicious software and could affect systems, data and business operations if not controlled.
Critical vulnerabilities	Fell from 67% in September to 55%	55% – Needs Improvement	A lower patching rate means more

patched	in February.		critical vulnerabilities may remain exposed for longer, increasing the possibility of exploitation and service disruption.
Security training completion	Improved from 45% in September to 70% in February.	70% – Improving	The improvement shows better employee participation, but more staff still need to complete training to strengthen the organisation's first line of defence.
High-risk security incidents	Increased from 2 in September to 7 in February.	7 – High	The increase indicates that security events are becoming more serious and could have financial, operational, regulatory and reputational consequences for GHC.

Overall Trend

The six-month trend shows that GHC's security exposure is increasing in several areas. Phishing attempts, malware incidents, and high-risk security incidents have all increased, while critical vulnerability patching has declined. Security training is the main positive trend, but the improvement in training has not yet been reflected in a reduction in security incidents. This

suggests that GHC needs to strengthen its preventive controls and continue improving employee awareness.

Evidence 9: Priority Risks and Actionable Recommendations

Based on the six-month security trends, the following two issues should be treated as priorities by GHC

Table 6: Priority Security Risks and Recommended Actions.

Priority Risk/Issue	Evidence	Potential Business Impact	Recommended Action
1. Increasing phishing and high-risk security incidents	Phishing attempts increased from 150 to 320, while high-risk incidents increased from 2 to 7 between September and February.	Increased risk of account compromise, data leakage, service disruption and damage to customer trust.	Strengthen phishing awareness and testing, improve email security controls and ensure that suspicious activity is reported and investigated quickly.
2. Declining critical vulnerability patching	Critical vulnerabilities patched decreased from 67% in September to 55% in February.	Unpatched vulnerabilities may be exploited and could result in system compromise, data loss, or operational disruption.	Establish clear patching targets and deadlines for critical vulnerabilities, with regular reporting to the Security Steering Committee and escalation of overdue critical patches.

Priority Recommendations

The first priority should be to reduce the organisation's exposure to phishing and other high-risk incidents. GHC should continue its security awareness programme while strengthening technical controls that can prevent or detect phishing attempts. Progress should be monitored through phishing results, reported suspicious emails, and high-risk incident trends.

The second priority should be to improve vulnerability management. GHC should set clear deadlines for addressing critical vulnerabilities and regularly review outstanding patches. Where a critical vulnerability cannot be patched within the agreed timeframe, the risk should be formally recorded, assessed, and escalated to the appropriate level of management.

Evidence 10: Rationale for Selecting the Five Board Metrics

The five metrics were selected because they give the Board a simple view of GHC's main security risks and how well the organisation is managing them. Phishing attempts, malware incidents and high-risk security incidents show the level of security threats affecting the organisation. Critical vulnerabilities patched shows how effectively GHC is addressing technical weaknesses, while security training completion shows the level of employee participation in security awareness activities.

Together, these metrics provide a balance between threat activity, technical protection and employee awareness. They also help management identify areas that require attention and make better decisions about security priorities and investment. The metrics can be monitored over time to determine whether security actions are improving GHC's overall risk position.

TASK 4: SECURITY STEERING COMMITTEE

Evidence 11: Security Steering Committee Terms of Reference

1. Purpose

The purpose of the GHC Security Steering Committee (SSC) is to provide a formal forum for discussing and making decisions on important information security matters. The Committee will help ensure that security decisions are aligned with GHC's business objectives, risk appetite, technology needs, and regulatory responsibilities.

2. Scope

The SSC will review significant information security risks, policies, security incidents, compliance matters, security investments and major security initiatives. It will also provide a forum for resolving disagreements between business and technical teams where security decisions may affect operations or business objectives.

3. Membership

The Security Steering Committee will include representatives from key areas of GHC:

- **CEO – Sarah Chen** – Executive sponsor
- **Director, Information Security Governance** – Committee coordinator
- **CTO – Elena Rodriguez** – Technology representative
- **IT Manager – John Smith** – IT operations representative
- **Senior Developer – Jane Doe** – Development representative
- **Compliance Officer – Mark Johnson** – Compliance and regulatory representative
- **HR Manager – Robert Green** – People and training representative
- **CFO – Marcus Thorne** – Finance and business-risk representative

Other employees or subject matter experts may be invited when their knowledge is relevant to a specific issue.

4. Responsibilities

The SSC will:

- Review significant information security risks and recommend appropriate actions.
- Review and support the development of security policies and standards.
- Monitor major security initiatives and agreed security improvement activities.
- Review significant security incidents and lessons learned.
- Consider the business, financial, technical and regulatory impact of security decisions.
- Review security metrics and trends provided by the Information Security Governance function.
- Support coordination between business and technology teams.
- Resolve or escalate significant disagreements relating to information security.
- Recommend security priorities and investments to executive management.

5. Meeting Cadence

The SSC will meet **monthly** to review security priorities, risks, metrics and ongoing activities. Additional meetings may be called when a significant security incident or urgent security decision requires attention.

6. Authority

The SSC is authorised to review security matters, request relevant information from GHC functions and make recommendations to executive management. Decisions that involve significant business risk, major financial investment, acceptance of significant security risk or changes requiring executive approval will be escalated to the CEO and, where appropriate, the Board.

7. Reporting

The Director of Information Security Governance will coordinate the Committee's activities and maintain records of meetings and decisions. Significant risks, unresolved issues and important recommendations will be reported to the CEO and escalated to the Board where necessary.

Evidence 12: Sample Agenda – First Security Steering Committee Meeting

GlobalHealth Connect (GHC)
Security Steering Committee (SSC)
First Meeting Agenda

Date: 18 September 2026

Time: 10:00 AM – 11:00 AM

Venue: GHC Main Conference Room

Chair: CEO – Sarah Chen

Coordinator: Director, Information Security Governance

Table 8: First Security Steering Committee Meeting Agenda

Agenda Item	Discussion/Objective	Lead
-------------	----------------------	------

1. Welcome and Opening	Welcome members and confirm the purpose of the Security Steering Committee.	CEO – Sarah Chen
2. Review of Committee Responsibilities	Confirm the Committee's responsibilities, authority and reporting arrangements.	Director, Information Security Governance
3. Current Security Risk Overview	Review key security risks and recent security concerns affecting GHC.	Director, Information Security Governance
4. Password Policy Proposal	Review the proposed requirement for 16-character complex passwords with changes every 30 days and no password-manager integration.	IT Manager – John Smith
5. CTO's Alternative Approach	Consider the CTO's recommendation for a more balanced approach using multi-factor authentication and secure password management.	CTO – Elena Rodriguez
6. Discussion and Decision	Compare the security, operational and user-impact implications of both approaches and agree on the preferred direction.	SSC Members
7. Action Points and Owners	Record the agreed actions, responsible persons, and expected completion	Director, Information Security Governance

	dates.	
8. Any Other Business	Discuss other important security matters raised by Committee members.	SSC Members
9. Closing	Confirm key decisions and next meeting date.	CEO – Sarah Chen

expected Outcome:

The Committee should agree on a password policy approach that provides appropriate security while remaining practical for employees and aligned with GHC's business and technology needs. Any issue requiring further assessment should be assigned to an owner and a clear follow-up action.

Evidence 13: CEO Briefing – Password Policy Conflict

The disagreement between the CTO and IT Manager should be resolved by considering both security and business needs. The proposed requirement for 16-character complex passwords with changes every 30 days may improve password strength, but it could also create difficulties for employees and encourage poor password practices if passwords are difficult to remember. The CTO's suggestion of using multi-factor authentication together with secure password management provides a more balanced approach. The Security Steering Committee should review the risks and practical impact of both options before making a final recommendation.

The recommended approach is to adopt a password policy that combines strong passwords, multi-factor authentication, and secure password management rather than relying only on frequent password changes. This approach supports GHC's security objectives while also considering employee productivity and ease of use. The decision should be documented, assigned to an owner for implementation, and reviewed to ensure that it provides the expected level of protection.

TASK 5: INFORMATION SECURITY GOVERNANCE MATURITY ASSESSMENT

Evidence 14: Information Security Governance Maturity Assessment

The maturity assessment below shows GHC's current position across six key information security governance areas. The assessment is based on the evidence provided in the scenario, including inconsistent policies, unclear responsibilities, reactive risk management and limited business-focused reporting.

Table 9: GHC Information Security Governance Maturity Assessment

Governance Domain	Current Level	Assessment
Policy & Documentation	Level 2 – Initial	GHC has security policies, but they are inconsistent, and some were inherited from acquired organisations. Policies are not always current or applied consistently.
Roles & Responsibilities	Level 1 – Ad Hoc	Security ownership and responsibilities are unclear, with some security activities being handled by the IT Manager without a clear governance structure.
Risk Management	Level 1 – Ad Hoc	Risk management is mainly reactive, and GHC does not currently have a formal proactive risk assessment process.
Metrics & Reporting	Level 2 – Initial	Technical security metrics are available, but they are not consistently translated into business impact for

		senior management and the Board.
Training & Awareness	Level 2 – Initial	Annual security training is mandatory, but employee engagement is low, showing that the process exists but needs improvement.
Compliance	Level 2 – Initial	GHC carries out compliance activities, but the approach is mainly focused on audits rather than continuous monitoring.

Overall Maturity Assessment

GHC's overall information security governance maturity is currently around **Level 2 – Initial**, with some areas still at Level 1. The organisation has some security activities and processes in place, but they are not yet consistently managed across the business.

The main areas requiring improvement are security ownership, proactive risk management, policy consistency, and business-focused reporting. GHC should focus on establishing clearly defined and documented processes so that it can reach **Level 3 – Defined** over the next 12–18 months.

Evidence 15: 12–18 Month Governance Improvement Roadmap

Based on the maturity assessment, GHC should focus on establishing clear and consistent governance processes before trying to move to more advanced maturity levels. The following roadmap identifies five priority initiatives that can help GHC reach at least Level 3 – Defined within 12–18 months.

Table 10: GHC 12–18 Month Information Security Governance Roadmap

Priority Initiative	Objective	Key Activities	Measurable Outcome	Timeline
1. Establish and standardise security policies	Create a consistent set of current security policies across GHC and its acquired organisations.	Review existing policies, remove outdated or conflicting requirements, approve standard policies and communicate them to staff.	Core security policies are documented, approved and reviewed regularly.	Months 1–4
2. Clarify security roles and accountability	Ensure that security responsibilities are clearly assigned across the organisation.	Formalise the Information Security Governance function, implement the RACI structure and establish the Security Steering Committee.	Key security responsibilities have named owners and the SSC meets regularly.	Months 1–3
3. Introduce proactive risk management	Move GHC from a mainly reactive approach to a more structured risk management process.	Create a security risk register, carry out regular risk assessments, assign risk owners and establish an escalation process.	Security risks are documented, assigned to owners and reviewed regularly.	Months 3–8
4. Improve	Provide	Select key	Regular Board-	Months 4–9

security metrics and reporting	management and the Board with security information that is easier to understand and use for decision-making.	security metrics, establish reporting formats and regularly report trends, risks and business impact.	level security reports are produced using agreed metrics and RAG status.	
5. Strengthen training, awareness and compliance monitoring	Improve employee security awareness and move compliance from an audit-focused approach to continuous monitoring.	Review training content, improve employee participation, conduct awareness activities, and establish regular compliance checks.	Training completion improves and compliance activities are monitored throughout the year.	Months 6–12

Evidence 16: Board Executive Summary – Governance Maturity

GHC's current information security governance maturity is around **Level 2 – Initial**, with some areas still at Level 1. Although the organisation has security policies, training and compliance activities in place, these are not yet consistently managed across the organisation. The main weaknesses are unclear security responsibilities, reactive risk management, inconsistent policies and limited reporting of security information in terms that support business decision-making.

Over the next 12–18 months, GHC should focus on establishing clear and consistent governance processes and moving towards **Level 3 – Defined**. The key priorities are to standardise security policies, clarify responsibilities, introduce proactive risk management, improve Board-level

security reporting, and strengthen training and compliance monitoring. Board support will be important in ensuring that these initiatives receive the appropriate resources, and that management remains accountable for the improvement programme.